



Presentación

Nombre: Yefri Ramirez

Técnico: Ciberseguridad

Módulo: Prueba De Penetración

Facilitador: Kevin Feliz Henríquez

Centro: Cyberclass

Nombre de la Practica: Fase Reconocimiento/Mapeo

Responde las Siguientes preguntas

- **¿Cuál es el objetivo principal de la fase de reconocimiento en un pentesting?**

El objetivo principal es recopilar la mayor cantidad de información posible sobre la organización objetivo. Sirve para mapear su infraestructura, identificar su superficie de ataque y planificar los vectores de entrada más efectivos.

- **¿Qué diferencias existen entre reconocimiento activo y pasivo?**

Reconocimiento Pasivo: No interactúa con el objetivo. Recopila información pública usando fuentes de terceros (Google, redes sociales, WHOIS). Es indetectable.

Reconocimiento Activo: Interactúa directamente con los sistemas del objetivo (escaneo de puertos, pruebas de servidores). Deja registros y puede ser detectado por sistemas de seguridad.

- **¿Qué información se debe recopilar durante esta fase?**

Durante la fase de reconocimiento se debe recopilar:

Datos de Red: Direcciones IP, bloques de red (Netblocks), nombres de dominio y subdominios.

Datos del Sistema: Servidores activos, sistemas operativos, puertos abiertos y servicios en ejecución (con sus versiones).

Datos de la Organización: Estructura de la empresa, ubicaciones físicas y tecnologías de seguridad utilizadas (como Firewalls o WAFs).

Datos de Usuarios: Nombres de empleados, correos electrónicos, números de teléfono y credenciales filtradas en internet.

- **¿Por qué es importante conocer el rango de IPs y los nombres de dominio del objetivo?**

Es importante por tres razones principales:

Evita problemas legales: Define los límites exactos del objetivo para asegurarte de atacar únicamente la infraestructura autorizada y no a un tercero por error.

Mapea la superficie de ataque: Permite descubrir servidores olvidados, entornos de prueba desprotegidos o servicios ocultos que no están a la vista del público.

Optimiza el tiempo: Ayuda a enfocar los esfuerzos y herramientas de escaneo exclusivamente en las direcciones y subdominios que pertenecen a la organización.

¿Cuáles son las principales herramientas utilizadas para el reconocimiento?

Para Reconocimiento Pasivo (Fuentes públicas, sin tocar al objetivo)

Whois: Identifica los datos de registro del dominio (dueño, fechas, servidores DNS).

TheHarvester: Busca correos electrónicos, nombres de empleados y subdominios en motores de búsqueda y redes como LinkedIn.

Shodan / Censys: Buscadores que encuentran dispositivos, servidores y cámaras conectados a internet en todo el mundo.

Maltego: Herramienta gráfica para cruzar datos y mapear las relaciones entre personas, dominios, IPs y empresas (OSINT).

Para Reconocimiento Activo (Tocando directamente los sistemas)

Nmap: La herramienta estándar para descubrir qué equipos están encendidos, qué puertos tienen abiertos y qué servicios ejecutan.

Gobuster / Dirsearch: Encuentran páginas, archivos y directorios ocultos en un sitio web mediante ataques de diccionario.

Subfinder / Amass: Herramientas diseñadas específicamente para descubrir todos los subdominios posibles de una organización.

Link de GitHub

<https://github.com/cyber-poli-rd/JS-Exposure>